🌐 Module 06: API and Java Web Token Penetration Testing

```
# Exercise 02: Performing API Reconnaissance using AI
```

Scenario

API reconnaissance is a critical preliminary step in web service penetration testing. Modern API frameworks (such as Swagger/OpenAPI, GraphQL, and gRPC) expose endpoints, data models, and authentication mechanisms through structural metadata.

Artificial Intelligence tools like **ShellGPT** (`sgpt`), driven by large language models (such as GPT-4), allow penetration testers to generate context-aware reconnaissance scripts on the fly. By translating natural language security prompts into executable shell pipelines, ShellGPT automates the extraction of API routes, structural enumeration, endpoint identification, and technology fingerprinting against target API services like **https://petstore.swagger.io/**.

In this exercise, we initialize ShellGPT with an activation key on Parrot Security, generate an automated API reconnaissance script, execute the commands, and save the structured enumeration output to **api_recon_results.txt**.

Objective

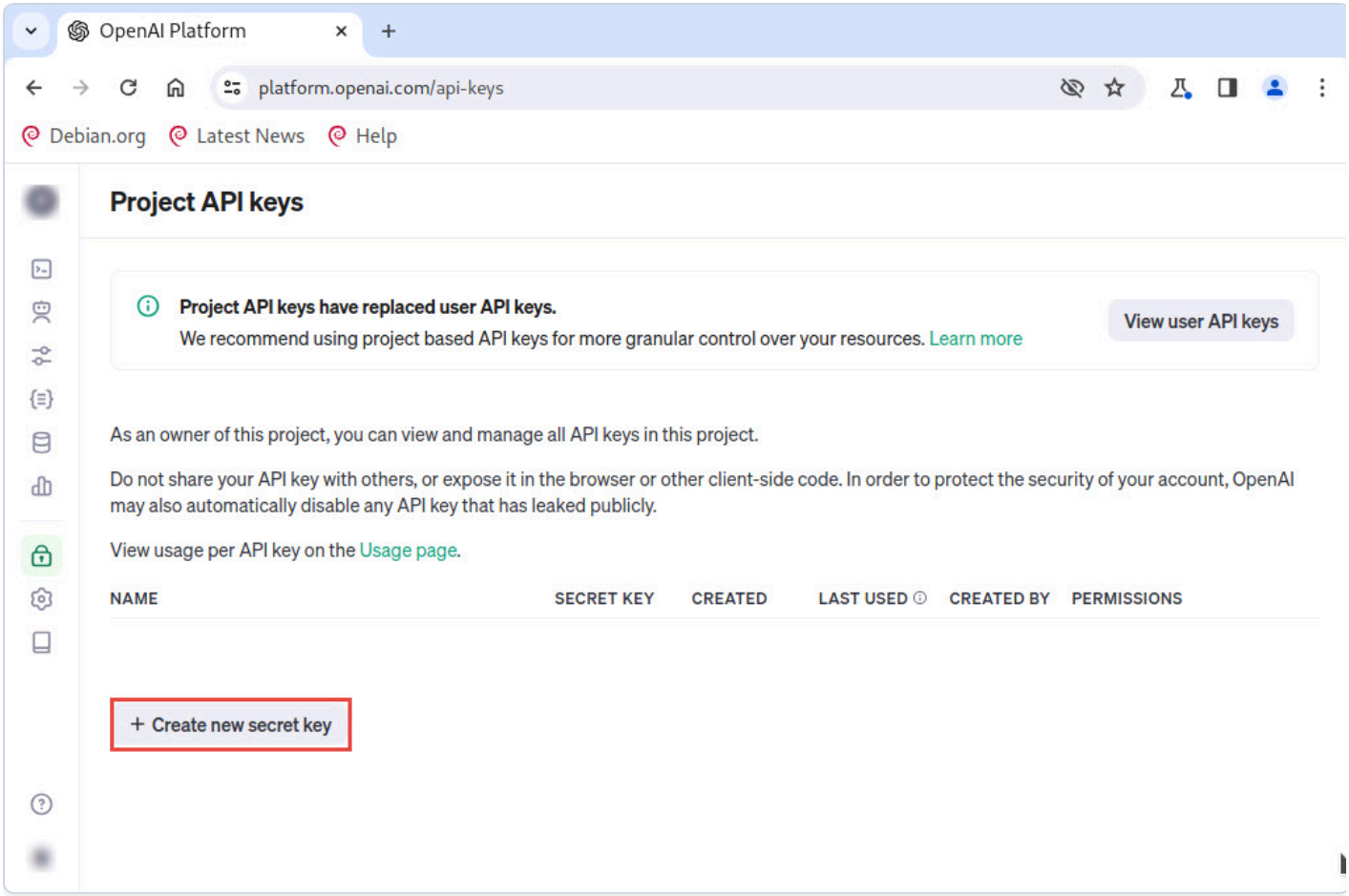
The objective of this lab is to help students learn how to:
- Configure and authenticate the ShellGPT (`sgpt`) AI integration tool on Parrot Security
- Formulate natural language shell generation prompts (`sgpt --shell`) for target API reconnaissance
- Automate the discovery of API endpoints, routing structures, and underlying technologies against **https://petstore.swagger.io/**
- Execute AI-generated bash pipelines and inspect structured output logs (**api_recon_results.txt**)

Task 1: Perform Automated API Reconnaissance using ShellGPT

In this task, we initialize ShellGPT with an API key, run a prompt to extract API routes and structural metadata for **https://petstore.swagger.io/**, execute the generated bash commands, and review the resulting analysis file.

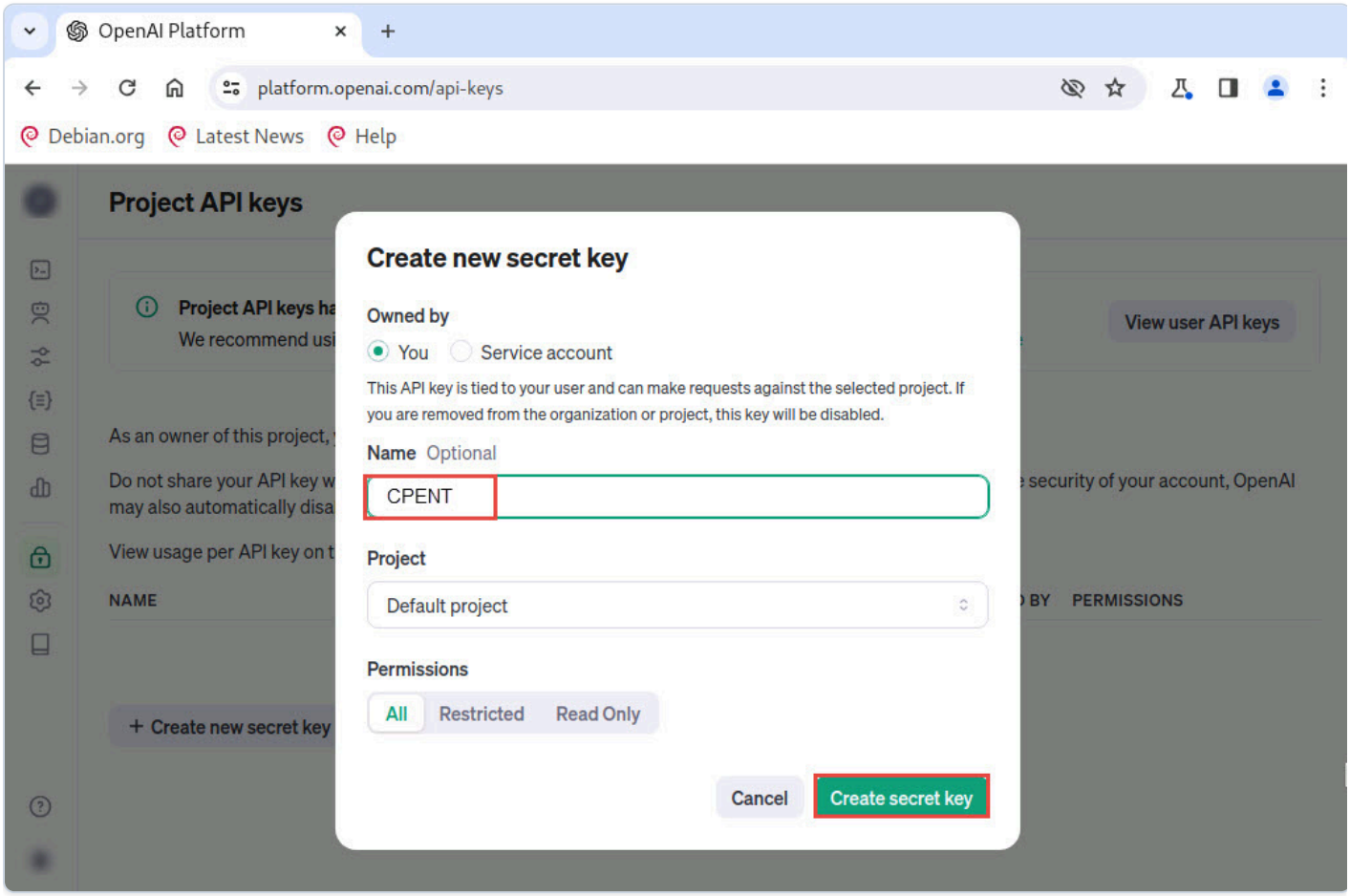
Lab Tasks

1. Switch to **Parrot Security** (**pentester** / **toor**), open a terminal window, and elevate to root:
   sudo su
   Enter password: **toor**

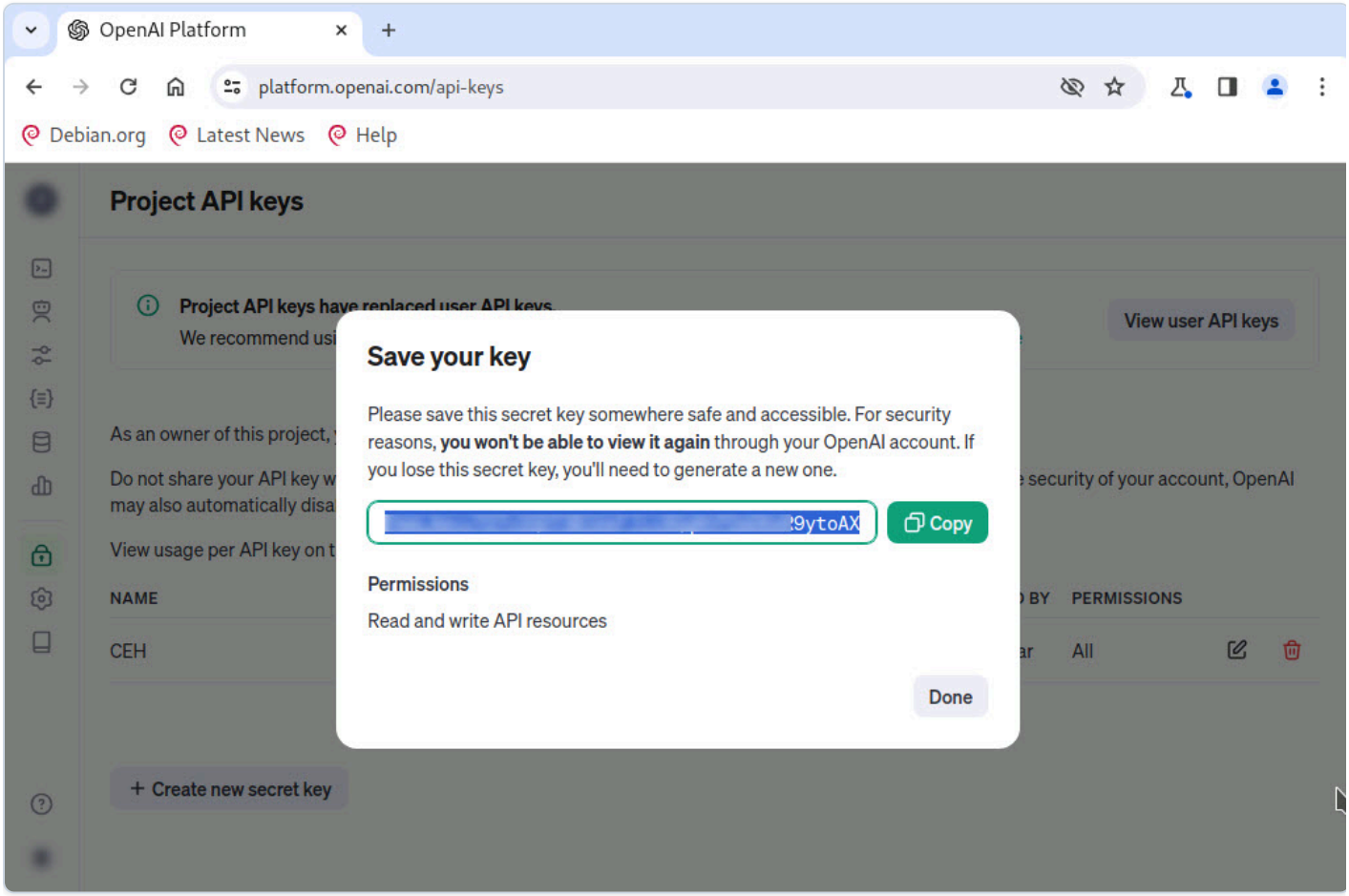


1. Configure the ShellGPT integration tool:

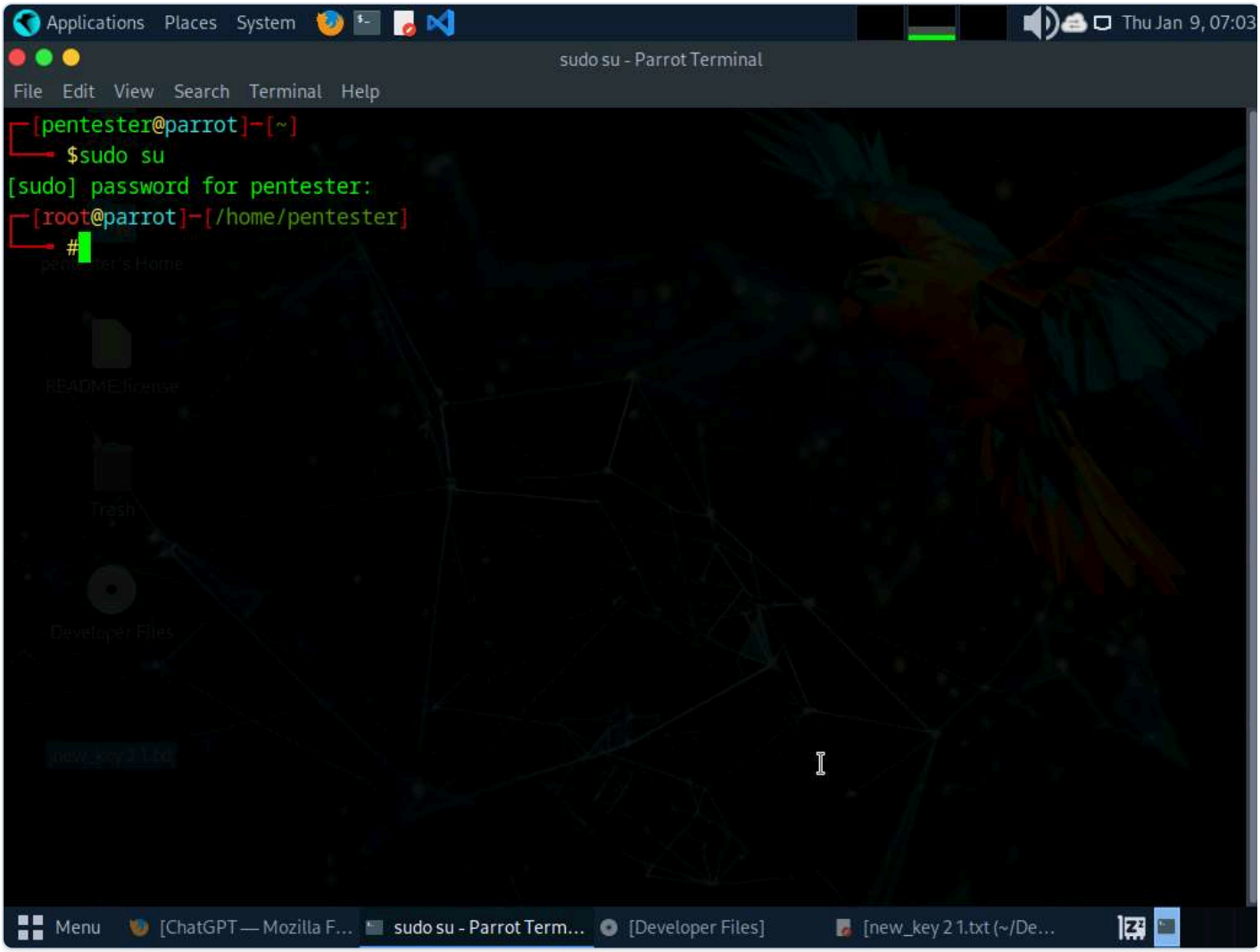
   bash sgpt.sh



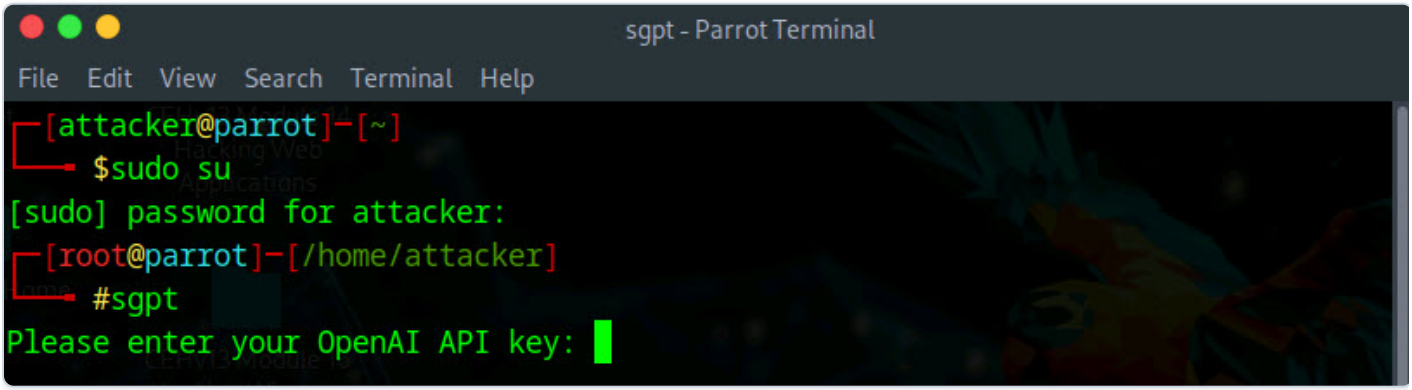
1. When prompted, enter your AI activation key (obtained from your ASPEN/iClass platform dashboard).



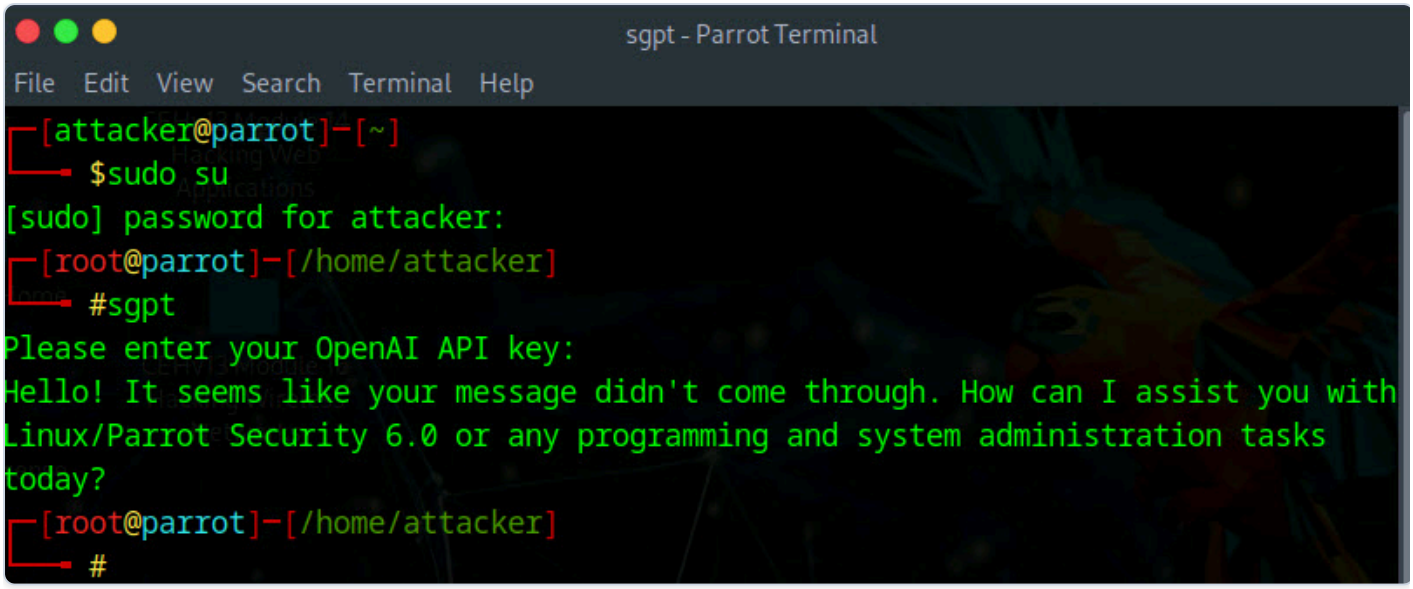
1. Verify that the AI key integration succeeds, displaying a success confirmation message.

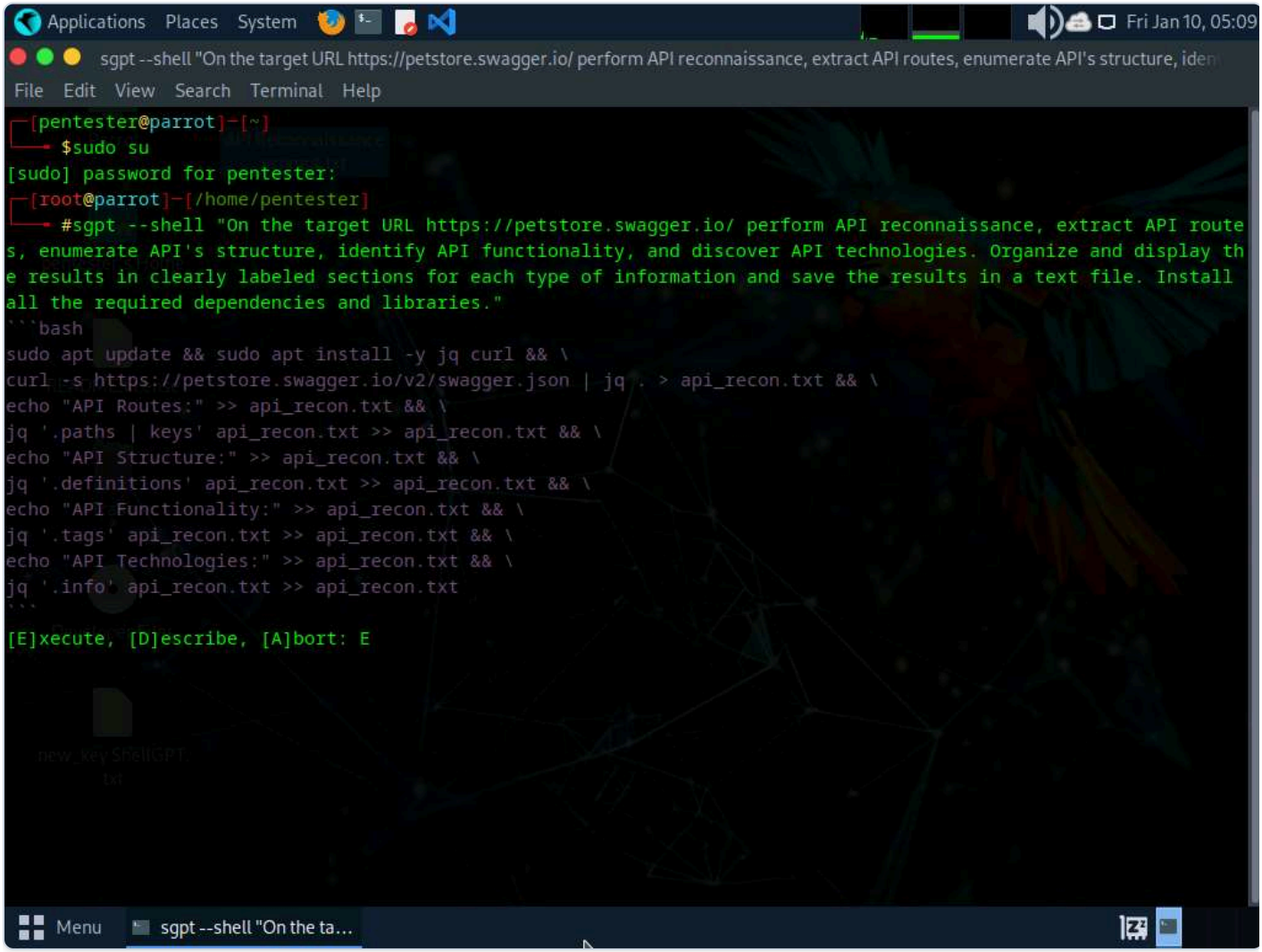


1. Issue the ShellGPT command to generate an API reconnaissance script targeting Swagger Petstore:
   sgpt --shell "On the target URL https://petstore.swagger.io/ perform API reconnaissance, extract API routes, enumerate API's structure, identify API functionality, and discover API technologies. Organize and display the results in clearly labeled sections for each type of information and save the results in a text file. Install all the required dependencies and libraries.Format the output like a real bash script with line breaks and \ characters."

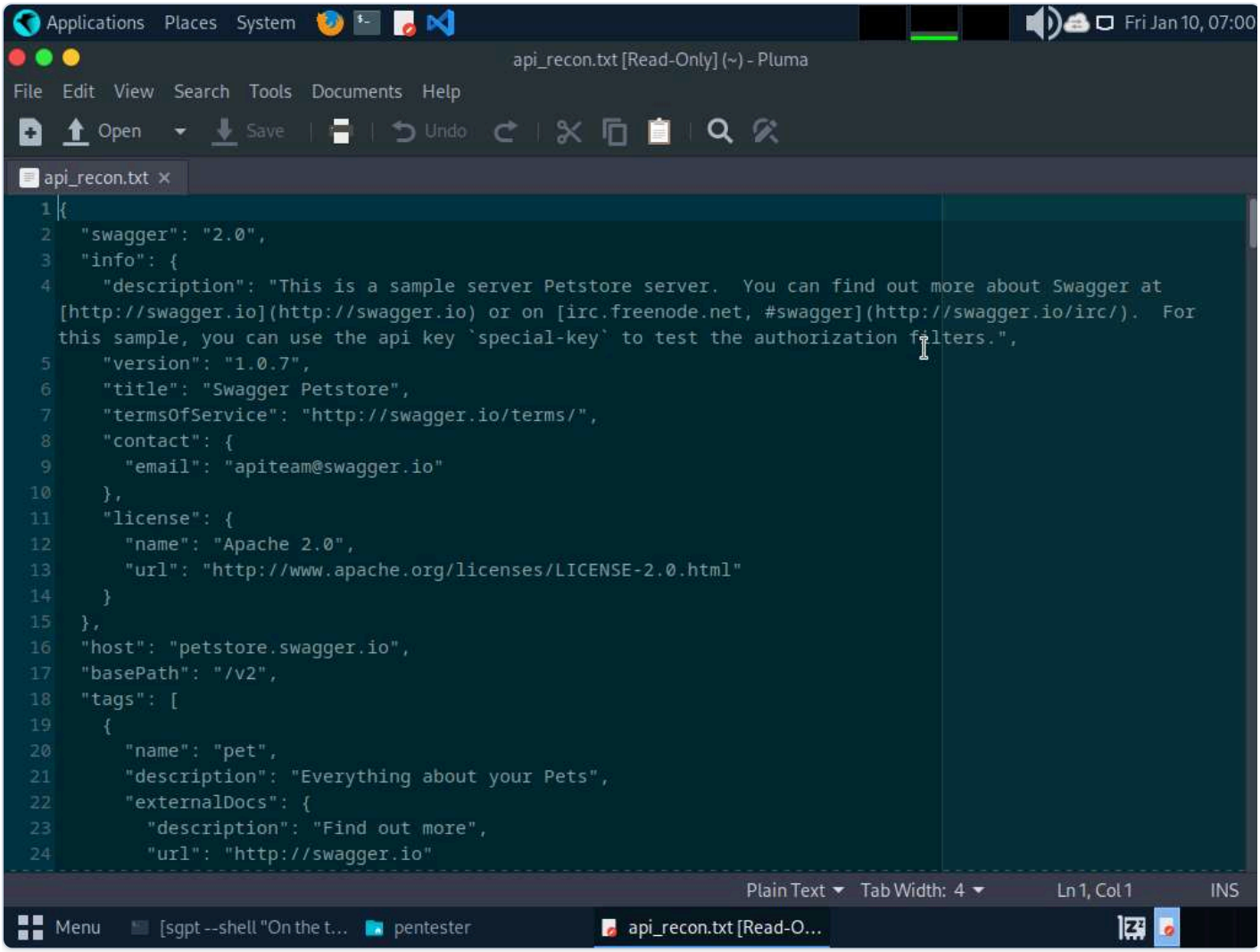


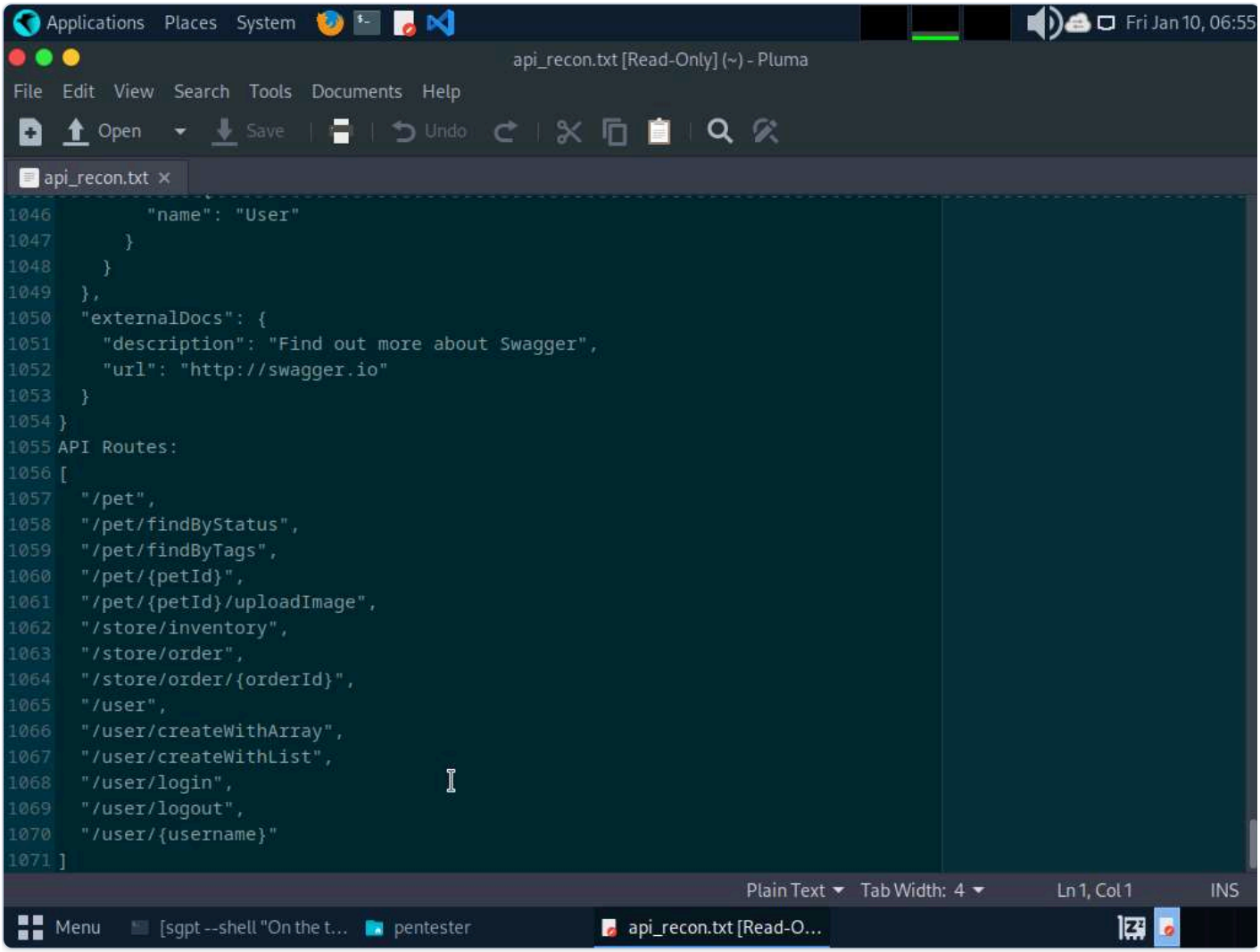
1. Review the AI-generated shell script proposal in the terminal. When prompted (*[E]xecute, [D]escribe, [A]bort*), type **E** and press Enter to execute the script.





1. Upon completion of script execution, open the generated results file for analysis:
   cat api_recon_results.txt


Applications Places System
Fri Jan 10, 07:00
api_recon.txt [Read-Only] (~) - Pluma
File Edit View Search Tools Documents Help
Open Save Undo
api_recon.txt
{
"swagger": "2.0",
"info": {
"description": "This is a sample server Petstore server. You can find out more about Swagger at http://swagger.io or on [irc.freenode.net, #swagger](http://swagger.io/irc/). For this sample, you can use the api key `special-key` to test the authorization filters.",
"version": "1.0.7",
"title": "Swagger Petstore",
"termsOfService": "http://swagger.io/terms/",
"contact": {
"email": "apiteam@swagger.io"
},
"license": {
"name": "Apache 2.0",
"url": "http://www.apache.org/licenses/LICENSE-2.0.html"
}
},
"host": "petstore.swagger.io",
"basePath": "/v2",
"tags": [
{
"name": "pet",
"description": "Everything about your Pets",
"externalDocs": {
"description": "Find out more",
"url": "http://swagger.io"
Plain Text Tab Width: 4 Ln 1, Col 1 INS
Menu [sgpt --shell "On the t... pentester api_recon.txt [Read-O...



1. Close all open terminal windows on Parrot Security.

This concludes the lab exercise.